MANAGEMENT DECISION · GENERAL EDITION

Security proposal for management

One shared foundation. Three complete protection packages.

Maximum 100 administrators | 2FA in every option | No additional servers to operate

Choose the common foundation plus one proposal. These are design recommendations, not implemented controls or a full cost quotation. Each item has two or three sentences, each with linked supporting evidence.

Strategy citations stay in this site and provide a return link. External sources open a new tab. In PDF and Markdown exports, strategy citations open the published general strategy so they work wherever the files are saved.

Contents

Common foundation

Proposal 1 · Lean AWS

Proposal 2 · AWS edge

Proposal 3 · Existing edge

Budget worksheet

Protect the organization and every AWS account

01 Named owners, segregation of duties and a control register

Assign named owners for AWS administration, security incidents, billing and the application through a RACI that covers the platform team, the application team, the steering committee, the national emergency authority and the edge vendor, and require that the production approver is never the author of the change. [Strategy: Ownership and approvals] Keep a control register as the basis for the ISO 27001 Statement of Applicability, with evidence that each control works, a quarterly risk review, and an approver and expiry date for every accepted exception. [Strategy: Everything as code] Report monthly to the steering committee using the metrics the strategy defines, most of which come straight from Security Hub, AWS Config, Inspector and GuardDuty. [Strategy: Metrics and reporting]

02 One AWS Organization with purpose-built accounts

Create an AWS Organization with a management account used only for Organizations, consolidated billing and IAM Identity Center, a Security organizational unit holding the security-tooling, log-archive and backup accounts, and a Workloads unit holding separate production and development accounts. [AWS multi-account guidance] Delegate GuardDuty, Security Hub, Inspector, AWS Config aggregation, IAM Access Analyzer and Macie to the security-tooling account, so day-to-day security work never touches the management account. [Strategy: Account security] Build the structure with Terraform in a separate organization pipeline that needs two-person approval, and move production into its own account before go-live if the timeline allows. [Strategy: Production account decision]

03 Service control policies that no administrator can bypass

Attach service control policies (SCPs) at the organization root that deny leaving the organization, deny every Region except the home Region, deny disabling CloudTrail, AWS Config, GuardDuty, Security Hub, Inspector, Macie or Access Analyzer, and deny creating IAM users, access keys or console passwords. [Strategy: Guardrail policies] Add SCPs that protect the platform roles, deny all root-user actions in member accounts, protect the log-archive buckets and keys, prevent weakening EBS encryption by default or S3 Block Public Access, and allow network changes such as internet gateways, peering and route tables only through the platform pipeline role. [Strategy: Network changes via pipeline] In the production unit make every human Identity Center role read-only except approved scaling actions and break-glass, test each policy in development for a week with IAM policy simulation before attaching it to production, and alert on any change to these policies. [Strategy: Read-only humans in production]

04 Resource control policies: a data perimeter around the organization

Attach resource control policies (RCPs) at the root that deny access to S3, KMS, Secrets Manager, SQS, STS and CloudWatch Logs from any identity outside our organization unless the caller is an AWS service, deny requests that are not encrypted in transit, and deny AWS services acting on our resources on behalf of another organization. [Strategy: Data boundaries] Before enforcement, inventory external access with IAM Access Analyzer external-access findings and list each legitimate integration, such as an edge vendor's log-delivery role, as an explicit exception so log delivery and backups keep working. [Strategy: Vulnerability and access analysis]

05 Secure defaults enforced by declarative policies and account baselines

Turn on all four S3 Block Public Access settings and EBS encryption by default with a customer managed KMS key in every account, and lock both with an SCP so no one can switch them off. [Strategy: Storage protection] Attach declarative policies at the root that block public AMIs and snapshots, enable VPC Block Public Access everywhere except the production public load balancer and NAT subnets, require IMDSv2 with a hop limit of one, disable serial console access, and allow machine images only from Amazon, the CIS image publisher and our own accounts. [Strategy: Secure defaults] Add the AI services opt-out policy, an organization backup policy applied by tag and a tag policy that standardizes environment, owner, data-class and component tags, and apply the whole baseline with one Terraform module whose state Security Hub checks. [Strategy: Required tags]

06 Named identities through IAM Identity Center with mandatory MFA

Give every person a named login through IAM Identity Center federated to the client's identity provider, with Microsoft Entra ID recommended and Identity Center's own directory as the fallback with a manual joiner-mover-leaver process. [Strategy: Identity provider decision] Require MFA on every sign-in, enforced in Identity Center when it holds the users or by an Entra ID Conditional Access authentication strength when federated, with FIDO2 security keys or passkeys mandatory for super administrators and governing-organization administrators and SMS and email codes switched off. [Strategy: Mandatory 2FA] Use permission sets for Viewer, Operator, Deployer and Auditor with no IAM users, cap console sessions at eight hours and administrator permission sets at one hour, disable accounts after 45 days without sign-in, and recertify all access every quarter. [Strategy: Identity controls]

07 Management account, root users and break-glass

Keep no workloads in the management account, allow at most two named administrators into it through Identity Center with security keys, and raise a P1 alert on any sign-in to it, because SCPs and RCPs never apply to the management account. [AWS management account guidance] Protect its root user with two hardware MFA keys kept in separate safes under a sealed-envelope custodian process, no access keys and a root-usage alarm, and use centralized root access to delete root credentials from every member account. [Strategy: Root protection] Keep two named, sealed break-glass identities whose every use pages the security owner and triggers a mandatory post-use review, and rehearse them before member root credentials are removed. [Strategy: Identity controls]

08 An immutable, organization-wide audit trail

Run one organization CloudTrail covering all accounts and Regions with log file validation and KMS encryption, plus AWS Config recording every resource type with an aggregator in the security-tooling account, both delivered to the log-archive account. [Strategy: Audit trail] Store security and audit logs in S3 with Object Lock in compliance mode for one year readily available plus six years in Glacier, keep operational logs 30 to 90 days, and give no human write access to the archive. [Strategy: Log retention] Ship load balancer, Envoy, edge, VPC Flow, EKS audit, pgaudit and administrator-access logs to the same archive, and add application audit events that record who changed which guidance object, from where and when. [Strategy: Logging]

09 Managed detection with alert-only routing

Enable GuardDuty for the whole organization with the S3, EKS audit and runtime, RDS and Malware Protection plans, Security Hub central configuration with the CIS AWS Foundations and Foundational Security Best Practices standards, Inspector for EC2, ECR and Lambda, and IAM Access Analyzer. [Strategy: Threat detection] Use Security Hub automation rules to suppress accepted exceptions and raise production severity, then route findings through EventBridge to one SNS topic per tier: P1 pages an on-call phone 24/7, P2 goes to chat through Amazon Q Developer in chat applications plus email, and P3 goes into a weekly digest. [Security Hub automation rules] Target acknowledgement within 15 minutes and containment within one hour for P1, attach a runbook link to every alert, and test the pipeline monthly with GuardDuty sample findings. [Strategy: Incident alerts]

10 Backups that an attacker or administrator cannot delete

Use an AWS Backup plan for the production PostgreSQL database with point-in-time recovery of at least seven days and daily snapshots kept for 35 days, copied to a vault in the separate backup account. [Strategy: Data protection] Lock that vault with AWS Backup Vault Lock in compliance mode so not even an administrator can delete copies early, and apply the plan through an organization backup policy keyed on tags. [AWS backup protection] Restore from the backup account every quarter, record the recovery time and data loss achieved, and have the business confirm they meet the service requirement. [Strategy: Metrics and reporting]

11 Changes only through reviewed code and keyless pipelines

Deploy account, network and cluster changes only from reviewed Terraform and Argo CD configuration, with GitHub Actions assuming AWS roles through an IAM OIDC provider whose trust is pinned to the repository, branch, environment and workflow, and with permission boundaries on every role the pipeline creates. [Strategy: Deployment identity] Harden the GitHub organization with SSO and MFA, branch protection with signed commits, CODEOWNERS on infrastructure and workflow files, required reviewers for production environments and no self-approval. [Strategy: Secure delivery] Alert at P2, or P1 in production, on any IAM user or access key, administrator policy, SCP or permission boundary created or changed outside the pipeline. [Strategy: Identity-change alerts]

12 Cost alarms as a security signal

Set AWS Budgets in every account and enable Cost Anomaly Detection, routing both to the billing and security owners as P2 alerts, because a sudden compute spike is often the first sign of crypto-mining after a credential leak. [Strategy: Cost alerts] Review actual monthly spend against the worksheet in this proposal, including detection, logs, backups, licences and staff time, remembering that budget alerts warn people but do not cap spending. [Cost Anomaly Detection]

13 Twelve go-live gates with evidence, not dates

Approve launch only when the twelve security gates pass, including working administrator login and role-based authorization, a public API reduced to an allow-list, AWS WAF in BLOCK after a clean seven-day COUNT period, signed images enforced, immutable logs, and Security Hub at 95 percent or better. [Strategy: Gate: administrator login] Require an independent penetration test with no open Critical or High findings after retest, a surge and DDoS drill with 500,000 simulated users that proves failover to the emergency page, and signed data retention, residency and DPIA decisions. [Strategy: Gate: surge drill] Present the evidence for each gate to the steering committee, and reject launch if unauthorized users can change guidance, the first restore from the backup account fails or the emergency fallback fails. [Strategy: Launch tests]

Start with the lowest-complexity AWS package

01 Best fit and trade-off

Choose this package when the public load balancer, protected by AWS WAF and the AWS Shield Standard protection that is included at no additional charge, passes the 500,000-user surge and DDoS drill without a content delivery network or an edge vendor in front of it. [AWS DDoS protection] It has the fewest moving parts and the lowest fixed cost, but every public request reaches the AWS Region directly, there is no edge cache or edge-served failover page, and the strategy's risk register rates outage under surge as Critical, so this package must disprove that risk in testing. [Strategy: Outage under surge]

02 Public entry: Application Load Balancer, AWS WAF and Shield Standard

Place an AWS WAF web ACL in BLOCK on the internet-facing Application Load Balancer with the AWS managed Core, Known Bad Inputs, SQL database, Linux and Admin Protection rule groups, plus the IP reputation and Anonymous IP lists, which work in this package because no proxy sits in front of the load balancer. [AWS WAF IP reputation groups] Add rate-based rules with separate thresholds for the position write path, the geo and routing lookups and site assets, set high enough for carrier-grade NAT and preferring Challenge over Block on read paths, and a positive allow-list that returns 404 for everything except the listed public methods and paths. [Strategy: Rate limits] Shield Standard covers common network and transport layer floods automatically; Shield Advanced is a separately priced subscription of USD 3,000 per month that this package does not assume. [AWS Shield pricing]

03 Location checks without blocking emergency readers

Do not geo-block public reads, because home-routed roaming makes a visitor inside the service area appear with a foreign IP address; instead label requests by country with a Count rule and apply stricter rate limits to traffic from outside the service country. [Strategy: Web attack protection] Enforce location for position writes in the application by rejecting coordinates outside the service-area polygon with PostGIS, implausible speeds between samples and out-of-range timestamps, and block anonymizers and hosting providers at AWS WAF on that write path only. [Strategy: Fake check-ins] Enforce administrator location at the identity provider and in the Verified Access policy, never at the public WAF. [Strategy: Location controls]

04 Administrator console: Verified Access, Identity Center and application RBAC

Publish one AWS Verified Access HTTP endpoint in front of the existing internal administrator load balancer that serves the Angular console and the admin gateway, with a non-descriptive hostname on a domain separate from the public site, a public ACM certificate, and the AWS WAF web ACL attached to the Verified Access instance. [Strategy: Administrator access] Use IAM Identity Center with mandatory MFA as the trust provider, grant the console through group-based Cedar policies that deny everything not listed, restrict client IP addresses to the service country with a time-boxed exception process, and keep sessions to eight hours. [Strategy: Group access policies] The admin gateway verifies the signed user-context token that Verified Access adds to every request, and the application still enforces its own OIDC login and role-based authorization, because the access layer is an outer gate rather than a substitute. [Strategy: Application identity]

05 Engineering access: two TCP endpoints and CloudShell, no jump server

Give super administrators two Verified Access TCP endpoints through the Connectivity Client: a network CIDR endpoint covering only the subnets holding the EKS control-plane interfaces on port 443, and an RDS endpoint that targets RDS Proxy rather than the database instance, with Argo CD reached through kubectl port-forward. [Strategy: Least-privilege endpoints] Use CloudShell VPC environments, which have no additional charge and run inside a chosen subnet, as the break-glass and Linux path, because the Connectivity Client runs only on Windows and macOS and CloudShell sessions end after 20 to 30 minutes idle. [Strategy: Serverless break-glass] Validate the trust provider against both the HTTP and TCP endpoints in development, run the new path in parallel with the Client VPN for two weeks with a written rollback, and only then remove the VPN endpoint. [Strategy: Access without VPN]

06 Inside the VPC: private EKS, segmented namespaces and controlled egress

Keep the EKS API endpoint private, run public and administrative workloads in separate namespaces under Pod Security Admission restricted, and apply default-deny NetworkPolicies that block all traffic between the public and admin namespaces in both directions, with each gateway reachable only from its own Envoy. [Strategy: Workload identities] Replace the broad proxied API prefix with exact-match HTTPRoutes for the public methods and paths, deny the Swagger, API-docs and actuator paths at the WAF, and apply the CIS NGINX settings for security headers and non-root operation. [Strategy: Public route allow-list] Delete the default VPC in every Region, add VPC endpoints for S3, ECR, STS, Secrets Manager, KMS and CloudWatch Logs, route remaining egress through AWS Network Firewall with a domain allow-list, and move service-to-service traffic to mutual TLS through Envoy or an ambient mesh. [Strategy: Outbound restrictions]

07 One identity per workload, one login per service

Map every Kubernetes service account to its own IAM role through EKS Pod Identity, for the web, public gateway, devices, geometry, routing, console, admin gateway, backend and migration workloads, with each role scoped to its own Secrets Manager secret and KMS key and automatic token mounting switched off. [Strategy: Workload identities] Replace the single superuser database login with a non-login owner role, a migration role used only by the Flyway job during deployments, separate login roles for the public devices service, the public geometry service and the admin backend with only the table rights each needs, and named DBA roles that use IAM authentication. [Strategy: Database permissions] Give each database user its own Secrets Manager secret behind RDS Proxy, set per-role connection limits and statement timeouts, force TLS to the database, and alert on any login as the master or owner role. [Strategy: Database anomaly alert]

08 Data protection and minimization

Encrypt everything with customer managed KMS keys per environment under split key policies with yearly rotation and an SCP that denies key deletion except through break-glass, keep RDS Multi-AZ with deletion protection and pgaudit, and mount secrets from Secrets Manager through the CSI driver. [Strategy: Data protection] Delete raw location samples 30 days after an event closes and keep only aggregates by area and time, remove the device email field, rotate device identifiers for each event, and run a DPIA and publish a privacy notice before launch. [Strategy: Data retention] Accept photos only through the admin plane with presigned S3 upload URLs, scan them with GuardDuty Malware Protection for S3, and serve them from a bucket that is never public. [Strategy: Photo upload decision]

09 Hardened images, signed releases and admission control

Build every Java service as a multi-stage image on a hardened Eclipse Temurin 17 JRE base from Docker Hardened Images, with Amazon Corretto as the fallback, pinned by digest and mirrored into ECR through a pull-through cache, and run it as a non-root numeric user with a read-only root filesystem, all capabilities dropped and no debug agent. [Strategy: Container protection] Keep the existing SBOM, provenance, Trivy and Inspector gates, cosign signing and immutable tags, and move Kyverno to Enforce so production accepts only signed images from the production ECR registry, with no privileged pods, no root user and the debug port denied. [Strategy: Secure delivery] Rebuild images weekly and whenever the base publishes a fix, patch Critical vulnerabilities within seven days or 48 hours when a public exploit exists, and add CodeQL or Semgrep, dependency review, gitleaks and an OWASP ZAP baseline scan to the pipeline with blocking thresholds. [Strategy: Application security]

10 Detection, response and the emergency fallback in this package

Route the strategy's P1 detections to the on-call responder, including guidance changed outside a change window, the public site or emergency page unreachable from synthetic canaries in two or more locations, any internet request reaching a blocked admin or device-list path at the origin, and any GuardDuty attack sequence. [Strategy: Incident alerts] Publish the signed static emergency page to S3 as the strategy requires, and because this package has no edge cache, switch to it with Route 53 health checks and DNS failover when the application is unhealthy. [Route 53 DNS failover] Amazon S3 website endpoints do not support HTTPS, so the surge drill must prove the fallback over HTTPS, which in practice means a minimal CloudFront distribution for the emergency page alone or a written acceptance of that gap. [S3 website endpoints]

11 Cost checkpoint, not a complete quote

At the cited list rates and 730 hours a month, one Verified Access web application at USD 0.27 per hour plus two TCP endpoints at USD 0.20 per hour cost about USD 489 per month, before data processing and other services. [Verified Access pricing] An AWS WAF example of one web ACL and ten billable rule entries adds USD 15 per month plus USD 0.60 per million inspected requests, the administrator web ACL is priced separately, and Shield Standard and IAM Identity Center add no charge. [AWS WAF pricing] Confirm the deployment-Region rates and Verified Access availability in the console before approval, and treat the common detection, logging, backup and labour allowances in the worksheet as planning estimates. [Strategy: Access options]

12 What the team still owns

This package adds no jump server, proxy, connector or monitoring server, but the platform team still operates the EKS cluster, the CIS Ubuntu nodes rebuilt monthly, the Terraform layers, the Kyverno policies and Argo CD, and the application team still owns the Phase 12 fixes. [Strategy: Shared responsibility] The team also owns WAF rule tuning after the COUNT period, the Cedar access policies, Connectivity Client updates on administrator devices, the incident playbooks, and the staged migration away from the current edge vendor and Client VPN. [Strategy: Responsibilities]

13 Management approval condition

Approve this package only if the production-like drill with 500,000 simulated users shows the public application and the HTTPS emergency fallback remain usable with the load balancer exposed directly, and an external scan confirms the admin and device-list paths return 404 or 403. [Strategy: Gate: surge drill] If that drill fails, or the traffic model shows the cache in Proposal 2 is cheaper than scaling the cluster beyond its four-node cap, select Proposal 2 rather than removing security controls to stay within budget. [Strategy: Outage under surge]

Add a managed edge for a surge-heavy public service

01 Best fit and trade-off

Choose this package when absorbing the surge at a global edge is worth a managed delivery layer: Amazon CloudFront in front of the public load balancer, AWS WAF evaluated at the edge, Shield Standard included, and the same Verified Access administrator path as Proposal 1. [CloudFront pricing] It stays AWS-only with no server to run and adds the edge-served emergency page the strategy calls for, but its value depends on measured traffic, on what can safely be cached, and on the residency decision accepting that public content is served from edge locations worldwide. [Strategy: Residency]

02 Public entry: CloudFront, AWS WAF at the edge and a locked origin

Attach an AWS WAF web ACL to the CloudFront distribution with the Core, Known Bad Inputs, SQL database, Linux and Admin Protection managed rule groups, the IP reputation and Anonymous IP lists, which see the real client at the edge, rate-based rules per path and the public route allow-list. [Strategy: Web attack protection] Restrict the Application Load Balancer security group to the AWS-managed prefix list for CloudFront origin-facing servers and require a secret origin custom header that a listener rule or a second AWS WAF web ACL on the load balancer checks, so nobody can bypass the edge. [AWS origin protection] Keep the origin web ACL in BLOCK as a second layer, reading the client address from the forwarded IP header for rate and geo rules, and alert at P1 if any request reaches a blocked admin or device-list path at the origin. [Strategy: Origin bypass alert]

03 Cache public content, never private responses

Cache site assets, the self-hosted map tiles once adopted, and the signed emergency page at CloudFront with custom caching rules, and exclude the position write path, administrator traffic and anything carrying personal data from the cache key and the cache. [CloudFront cache keys] Define how fast changed guidance must become visible and use CloudFront invalidations in the publishing procedure, rehearsing an emergency update so the cache can never serve dangerously outdated instructions. [CloudFront invalidation] Configure a CloudFront origin group with the application as primary and the S3 emergency page as secondary, so GET requests fail over at the edge when the origin returns errors or times out, which is the edge failover the strategy requires. [CloudFront origin failover]

04 Location checks with the real client visible at the edge

Do not use CloudFront geographic restrictions on public reads, because they block whole countries and roaming visitors inside the service area appear foreign; label requests by country at the edge web ACL and apply stricter rate limits outside the service country. [CloudFront geographic restrictions] Validate position writes in the application with the PostGIS polygon, speed and timestamp checks, and block anonymizers and hosting providers on the write path at the edge, where AWS WAF sees the real client address. [Strategy: Web attack protection] Enforce administrator location at the identity provider and in the Verified Access Cedar policy, with mandatory MFA as the primary control and location as a secondary check. [Strategy: Location controls]

05 Administrator console: Verified Access, Identity Center and application RBAC

Keep the administrator console entirely off the CloudFront distribution: one Verified Access HTTP endpoint fronts the internal administrator load balancer on its own low-visibility domain with a public ACM certificate and the AWS WAF web ACL attached to the Verified Access instance. [Strategy: Low-visibility name] IAM Identity Center with mandatory MFA is the trust provider, group-based Cedar policies grant the console to the location, governing-organization and super administrator groups, sessions last eight hours, and the admin gateway verifies the signed user-context token on every request. [Strategy: Group access policies] Alert at P2 on sign-ins from unexpected countries or hours and on repeated failures, and at P1 on any change to Verified Access policies, trust providers or the web ACL, on any MFA reset, and on any administrator created outside the inventory. [Strategy: Access logging]

06 Engineering access: two TCP endpoints and CloudShell

Super administrators reach the private EKS API through a Verified Access network CIDR endpoint on port 443 and RDS Proxy through a Verified Access RDS endpoint, both via the Connectivity Client, with security groups admitting only the Verified Access endpoint. [Strategy: Least-privilege endpoints] CloudShell VPC environments are the break-glass path when Verified Access or the identity provider fails during an event, reaching the EKS API, RDS Proxy and the admin gateway from inside the VPC with no server to maintain. [Strategy: Serverless break-glass] Confirm that Verified Access and CloudShell VPC environments are offered in the deployment Region, and keep the Client VPN until two weeks of parallel running are complete. [Strategy: Administrator access]

07 Inside the VPC: the same segmentation as Proposal 1, plus origin isolation

The private EKS endpoint, separate public and admin namespaces under Pod Security Admission restricted, default-deny NetworkPolicies, exact-match public HTTPRoutes, VPC endpoints, a Network Firewall domain allow-list and mutual TLS between services apply exactly as in Proposal 1. [Strategy: Network protection] In addition, VPC Block Public Access excludes only the public load balancer and NAT subnets, and that load balancer accepts traffic only from the CloudFront prefix list, so the origin has no internet path except through the edge. [Strategy: VPC public-access block]

08 One identity per workload, one login per service

EKS Pod Identity maps each service account to its own IAM role scoped to one Secrets Manager secret and KMS key, with service account tokens not mounted and no application Role or RoleBinding in the cluster. [Strategy: Workload identities] The database uses a non-login owner, a Flyway migration role, separate login roles for the public devices service, the geometry service and the admin backend, and named DBA roles with IAM authentication, each behind RDS Proxy with its own secret and connection limit. [Strategy: Database permissions] Separate connection pools mean a public flood cannot starve the administrator plane, and any login as the master or owner role raises an alert. [Strategy: Database anomaly alert]

09 Data protection, minimization and what the edge may hold

Apply the same KMS, Secrets Manager, RDS and retention controls as Proposal 1: customer managed keys per environment, raw location samples deleted 30 days after an event closes, the device email removed, rotating device identifiers, a DPIA and a privacy notice. [Strategy: Data retention] Verify that CloudFront caches and standard logs retain no personal data, deliver CloudFront access logs to the log-archive bucket in the home Region, and record in the residency decision that cached public content is served from edge locations worldwide. [CloudFront access logs] CloudFront is one of the global services the Region guardrail must exempt, because its control-plane calls are made in us-east-1, so list that exemption explicitly in the SCP. [Strategy: Region safeguards]

10 Hardened images, signed releases and admission control

Identical to Proposal 1: hardened Temurin JRE images pinned by digest and mirrored through an ECR pull-through cache, non-root with a read-only filesystem and no debug agent, cosign signatures verified by Kyverno in Enforce, and a registry allow-list limited to production ECR. [Strategy: Container protection] Weekly rebuilds, seven-day Critical patching, and SAST, dependency review, secret scanning and DAST gates in the pipeline, with Argo CD rollback kept as the tested recovery for a bad release. [Strategy: Secure delivery]

11 Detection, response and the edge-served fallback

Route the same P1 and P2 detections as Proposal 1 to the on-call responder, with CloudWatch Synthetics canaries from two or more locations watching the public site and the emergency page through CloudFront. [CloudWatch Synthetics canaries] The emergency page lives in S3 behind the CloudFront origin group, so failover happens at the edge for GET requests without a DNS change, and the DDoS playbook adds AWS Shield engagement and the pre-approved event-mode scale profile. [Strategy: Emergency fallback] Rehearse the failover and an emergency guidance update in the surge drill, because CloudFront fails over only after a request to the primary origin fails and never fails over POST requests. [CloudFront origin failover]

12 Compare total edge cost before buying

Budget about USD 489 per month for the Verified Access configuration, then price CloudFront either pay-as-you-go or on a flat-rate plan: the Business plan at USD 200 per month includes AWS WAF, advanced DDoS protection, JavaScript challenge, custom caching rules and logging, with an allowance of 125 million requests and 50 TB. [Verified Access pricing] Origin failover is listed only from the Premium plan at USD 1,000 per month upward, so the edge-served emergency fallback in this package needs Premium or pay-as-you-go pricing, and the worksheet's USD 200 starting value must be revised once the plan is chosen. [CloudFront pricing] Use normal and emergency traffic forecasts, check which WAF features and logs each plan includes so the budget neither double-counts bundled protection nor treats the smallest plan as adequate for a surge, and confirm all rates before approval. [CloudFront pricing]

13 What the team still owns and the approval condition

AWS operates CloudFront, WAF, Shield and Verified Access, but the team still maintains the application, the cluster and its policies, the caching and invalidation rules, the origin header secret, and the administrator devices. [Strategy: Responsibilities] Approve this package only after the traffic model, an origin-bypass test proving that a direct connection to the load balancer is refused, a cache-update test, the surge drill with edge failover, and the residency review justify its cost over Proposal 1. [Strategy: Launch tests]

Retain Imperva where its contract justifies the cost

01 Best fit and trade-off

Choose this package when the existing Imperva cloud WAF, on a tier with bot management and a DDoS service-level agreement, avoids a costly migration or provides contractually valuable incident support, with AWS WAF at the origin and Verified Access for administrators exactly as in the other packages. [Strategy: Imperva decision] It is the architecture the strategy was written against, and the only one where IP reputation and anonymizer filtering for the public plane happen at a layer that sees the real client, but do not assume it is cheaper or more secure because it uses two vendors, and obtain a written price and scope confirmation. [Strategy: Web attack protection]

02 Public entry: Imperva as the first filter

Keep Imperva as the public entry point with its default WAF Rules policy blocking SQL injection, cross-site scripting, illegal resource access and remote file inclusion, backdoor protection on Auto-Quarantine, and bot access control denying bad bots while allowing good ones, confirming that no site or rule has been switched to Alert Only. [Strategy: Edge attack rules] Tune the DDoS detection threshold for 500,000 concurrent users so a real event does not look like an attack, add an Imperva ACL allow-list for the public methods and paths, rate rules per path, and reputation and anonymizer blocking on the write path only. [Strategy: DDoS threshold] Never place a CAPTCHA on public pages; use a JavaScript challenge only on the position write path and only while under attack, and confirm which rules, support, traffic allowances and emergency commitments the contract actually includes. [Strategy: Bot control]

03 Do not let attackers go around Imperva

Restrict the origin Application Load Balancer security group to the Imperva prefix list and make origin mutual TLS mandatory, with the load balancer validating Imperva’s client certificate against an ALB trust store, so a direct connection to the origin is refused. [Strategy: Origin guard] Keep an AWS WAF web ACL in BLOCK on the origin load balancer with the Core, Known Bad Inputs, SQL database, Linux and Admin Protection managed rule groups and the exact public route allow-list, but leave the AWS IP reputation groups off because they would only see Imperva’s addresses. [Strategy: Visitor reputation] Configure the origin rate-based and geo rules to read Imperva’s client IP header, strip that header if it arrives from anywhere else, and alert at P1 if any request reaches a blocked admin or device-list path at the origin. [AWS WAF forwarded IP]

04 Visitor checks where the real visitor is visible

Do IP reputation, anonymizer and country checks at Imperva, because the origin sees only the proxy address, and label public reads by country rather than blocking them so roaming visitors inside the service area still receive guidance. [Strategy: Visitor reputation] If hard country blocking is wanted anyway, apply it only to the write path with Imperva's ACL Block Countries and record the accepted impact on roaming visitors, while the application validates every submitted coordinate against the service-area polygon. [Imperva policies] Administrator location is enforced at the identity provider and in Verified Access, not at the public edge. [Strategy: Location controls]

05 Administration stays off the public edge

Administrators never pass through Imperva: one Verified Access HTTP endpoint fronts the internal administrator load balancer on a separate low-visibility domain, with the AWS WAF web ACL on the Verified Access instance using the IP reputation and Anonymous IP lists, which work there because no proxy is in front. [Strategy: Administrator web firewall] IAM Identity Center with mandatory MFA is the trust provider, Cedar policies grant the console per group, sessions last eight hours, and the admin gateway verifies the signed user-context token while the application keeps its own OIDC login and role-based authorization. [Strategy: Application identity]

06 Engineering access without a server to maintain

Two Verified Access TCP endpoints, a network CIDR endpoint for the EKS API on port 443 and an RDS endpoint targeting RDS Proxy, serve super administrators through the Connectivity Client, with Argo CD reached by kubectl port-forward. [Strategy: Administrator access] CloudShell VPC environments cover break-glass and Linux users at no additional charge, and the Client VPN is removed only after two weeks of parallel running with a written rollback. [Strategy: Access without VPN]

07 Contain attacks after the public boundary

The same private EKS endpoint, public and admin namespaces under Pod Security Admission restricted, default-deny NetworkPolicies, exact-match HTTPRoutes and CIS-hardened NGINX apply as in Proposal 1. [Strategy: Network protection] VPC endpoints for S3, ECR, STS, Secrets Manager, KMS and CloudWatch Logs plus AWS Network Firewall with a domain allow-list remove every internet path except named destinations, and mutual TLS between services through Envoy or an ambient mesh closes the plain-HTTP gap inside the cluster. [Strategy: Outbound restrictions]

08 Avoid shared powerful accounts

One Kubernetes service account per workload mapped to one IAM role through EKS Pod Identity, scoped to its own secret and key, with no application Role or RoleBinding and token mounting off. [Strategy: Workload identities] Separate database logins for the public devices service, the geometry service, the admin backend and the Flyway migration job, a non-login owner role, named DBA roles with IAM authentication, per-user secrets behind RDS Proxy, and the master account reserved for break-glass with an alert on every login. [Strategy: Database permissions]

09 Protect personal data across both providers

Apply the same KMS, Secrets Manager, RDS, backup and retention controls as the other packages, including deletion of raw location samples 30 days after an event closes and removal of the device email field. [Strategy: Data protection] Review where Imperva processes traffic and stores logs, require log delivery to an S3 bucket in the home Region and confirm it before go-live, and record in the supplier register the data processing agreement, residency commitment and security clauses the contract provides. [Strategy: Imperva decision] Treat any Imperva log or point-of-presence data held outside the approved territory as the residency drift risk the strategy already lists, and bring it to the steering committee for explicit approval. [Strategy: Residency drift]

10 Enforce safe releases internally

Hardened Temurin JRE images pinned by digest through an ECR pull-through cache, non-root with no debug agent, cosign verification and a registry allow-list enforced by Kyverno, and the SBOM, provenance, Trivy and Inspector gates stay exactly as in Proposal 1. [Strategy: Container protection] Weekly rebuilds, vulnerability SLAs of 7, 30 and 90 days, pipeline SAST, dependency review, secret scanning and DAST, and a tested Argo CD rollback complete the release controls. [Strategy: Secure delivery]

11 One response process across two vendors

Send Imperva DDoS and attack notifications, AWS findings and application audit alerts to the same tiered SNS routing, with Imperva alerts at P2 that become P1 during an event or drill, and clear instructions in each runbook for contacting each provider. [Strategy: Edge DDoS alert] Cache the signed static emergency page at Imperva as the origin-failover target, and include Imperva escalation, AWS Shield and the event-mode scale profile in the DDoS playbook. [Strategy: Emergency fallback] Run a joint incident exercise with Imperva before each national exercise so a provider hand-off does not delay recovery. [Strategy: Recovery]

12 Price the contract and the duplicate inspection

Add the quoted Imperva service and support cost to about USD 489 per month for Verified Access, the AWS WAF web ACL at the origin inspecting every request that passes Imperva, and the common detection, logging and backup allowances. [Strategy: Imperva decision] Compare that total and the migration avoided against Proposals 1 and 2, including traffic overages, contract commitments and incident support, and replace the worksheet’s placeholder with the actual contract figure before approval. [Verified Access pricing]

13 What management must accept

No new connector or jump server is required, but the team operates the existing workloads and coordinates WAF rules, log delivery, residency evidence and incidents across AWS and Imperva, with the edge vendor held in the supplier register under contract clauses and collected evidence. [Strategy: Ownership and approvals] Approve this package only when the contract, the tested protection including mandatory origin mutual TLS, and the migration savings justify that additional cost and coordination. [Strategy: Gate: origin accepts only the edge]

BUDGET WORKSHEET · INSIDE THIS PROPOSAL

Common costs + your chosen option

Every field starts with an editable estimate so you can compare Common plus each option immediately. These are **planning estimates, not approved budgets or vendor quotes**; clearing a field makes it unpriced, not free.

Simple planning assumptions

USD per month, 730 hours, at most 100 administrators, one web access application and two technical endpoints. Rates were checked on 22 October 2026 against Verified Access pricing and WAF pricing; confirm deployment-region rates before approval.

Public requests per month, in millions 10

Ten million requests is a comparison example, not a forecast from the administrator count or the emergency-user count. WAF examples assume one ACL and ten billable rule entries per inspected layer; advanced rules, challenges and extra inspection can cost more.

The basis notes explain the starting estimates; if you edit a field, they do not become a new quote or automatically change the assumed scope. Labour uses a planning rate of USD 100 per hour, and routine operations assume existing on-call coverage.

Common · pay once, whichever option you choose

Cost item	Monthly USD	Basis
Account safeguards	USD 0.00	Organizations has no additional service charge; configuration work is below.
Threat detection and security checks	USD 300.00	Planning allowance: GuardDuty 100 + Security Hub 100 + Inspector 50 + Config 50 per month; validate against actual account and workload usage. See usage pricing.
Logs, backups and other security usage	USD 250.00	Planning allowance: logs and retention 75 + backups 125 + keys, secrets and access usage 50 per month; validate storage growth and restore costs. See log pricing.
Ongoing security operations	USD 1,200.00	Planning allowance: 12 hours per month × USD 100 for reviews, patching and routine response; assumes an existing on-call team, not new 24/7 staffing.
Additional identity licences	USD 300.00	Planning allowance: 100 administrators × USD 3 per month for any additional identity licences; not a vendor price, and removable if existing licences suffice. IAM Identity Center itself has no extra charge.
Shared setup and security assessment · one-time USD Planning allowance: 40 hours × USD 100 for shared controls, plus USD 4,000 for penetration testing and retesting; replace with scoped estimates.		USD 8,000.00

Common priced subtotal: **USD 2,050.00 (estimate)** per month.

Proposal 1 · Lean AWS

Cost item	Monthly USD	Basis
Verified Access web application	USD 197.10	730 hours × USD 0.27; private administrator website.
Verified Access technical connections	USD 292.00	Two endpoints × 730 hours × USD 0.20; cluster and database.
Administrator web firewall	USD 15.60	One ACL, ten billable rule entries, one million requests.
Public web firewall	USD 21.00	USD 5 + ten rule entries + USD 0.60 per million public requests.
Implementation and testing for this option · one-time USD Planning allowance: 20 hours × USD 100 for access, firewall configuration and testing.		USD 2,000.00

Option-only priced subtotal: **USD 525.70 (estimate)** per month, before Common.

Proposal 2 · AWS edge

Cost item	Monthly USD	Basis
Verified Access web application	USD 197.10	730 hours × USD 0.27; private administrator website.
Verified Access technical connections	USD 292.00	Two endpoints × 730 hours × USD 0.20; cluster and database.
Administrator web firewall	USD 15.60	One ACL, ten billable rule entries, one million requests.
CloudFront package including public WAF	USD 200.00	Business plan example: USD 200; that plan does not list origin failover, which the edge-served emergency page needs, so expect the Premium plan or pay-as-you-go pricing and confirm features and traffic limits before choosing.
Implementation and testing for this option · one-time USD Planning allowance: 30 hours × USD 100 for access, edge configuration and testing.		USD 3,000.00

Option-only priced subtotal: **USD 704.70 (estimate)** per month, before Common.

Proposal 2 counts public WAF inside the example CloudFront package, not again as a separate charge. If choosing pay-as-you-go instead, enter the combined CDN and public WAF estimate in that field.

Proposal 3 · Existing edge

Cost item	Monthly USD	Basis
Verified Access web application	USD 197.10	730 hours × USD 0.27; private administrator website.
Verified Access technical connections	USD 292.00	Two endpoints × 730 hours × USD 0.20; cluster and database.
Administrator web firewall	USD 15.60	One ACL, ten billable rule entries, one million requests.
AWS firewall at the public origin	USD 21.00	Conservative example: all entered public requests reach this inspection layer.
Imperva service and support	USD 1,000.00	Planning placeholder: USD 1,000 per month for service and support, not an Imperva quote; replace with the actual contract cost.
Implementation and testing for this option · one-time USD Planning allowance: 30 hours × USD 100 for access, vendor integration and testing.		USD 3,000.00

Option-only priced subtotal: **USD 1,525.70 (estimate)** per month, before Common.

Decision total

Common + Proposal 1: USD 2,575.70 (estimate) per month. First year, including one-time costs: USD 40,908.40 (estimate).

Common + option	Monthly	Yearly recurring	One-time
Proposal 1	USD 2,575.70 (estimate)	USD 30,908.40 (estimate)	USD 10,000.00 (estimate)
Proposal 2	USD 2,754.70 (estimate)	USD 33,056.40 (estimate)	USD 11,000.00 (estimate)
Proposal 3	USD 3,575.70 (estimate)	USD 42,908.40 (estimate)	USD 11,000.00 (estimate)

Totals are incremental security planning estimates, not a full website-running-cost quote. Existing application hosting, load balancers, database and cluster capacity, taxes and general internet delivery are excluded unless explicitly included in a package; do not count the same cost twice.

The Common usage allowance includes a starter amount for access data processing and connection charges; increase it when usage is known. Confirm licences, emergency capacity, retention volumes, support and migration scope before approval; the estimate includes no contingency or separately purchased 24/7 response service.